2025

Comú d'Encamp

ANDORRA

Política de Seguretat de la Informació

COMÚ D'ENCAMP

Control de versió

Control del document

	Nom	Classificació	Data
Fet per:	Awesome S.L.	Normativa	24-11-2023
Aprovat per:	Junta de Govern	Normativa	24-11-2023

Registre de canvis

Revisió	Versió	Descripció del canvi	Modificat per
Nov-2025	1.1.	Es canvia el format a la plantilla actual de documents del SGSI del Comú	DSI

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

Índex

1 Aprovació i entrada en vigor 4
2 Introducció 4
3 Missió del Comú 4
4 Abast 5
5 Normativa de referència 5
6 Motivació del sistema de gestió de seguretat de la informació 6
7 Objectius de seguretat de la informació 7
8 Estructura del Sistema de Gestió de la Seguretat de la Informació 7
9 Organització de la seguretat 8
9.1 Rols o perfils de seguretat 8
9.2 Comitè de Seguretat de la Informació 8
9.3 Dades de contacte del DSI 8
10 Requisits de seguretat bàsics 8
10.1 Seguretat com un procés integral 9
10.2 Principi de mínim privilegi 9
10.3 Vigilància contínua, reavaluació periòdica i Integritat, actualització del sistema i millora contínua del procés de seguretat 9
10.4 Gestió de personal i professionalitat 10
10.5 Gestió de la seguretat basada en els riscos i anàlisi i gestió de riscos 10
10.6 Incidents de seguretat, prevenció, reacció i recuperació 11
10.7 Línies de defensa i prevenció davant d'altres sistemes interconnectats 12
10.8 Funció diferenciada i organització i implantació del procés de seguretat 12
10.9 Autorització i control dels accessos 12
10.10 Protecció de les instal·lacions 12
10.11 Adquisició de productes de seguretat i contractació de serveis de seguretat 12
10.12 Protecció de la informació emmagatzemada i en trànsit 13
10.13 Continuïtat de l'activitat 13
10.14 Registres d'activitat 13
10.15 Infraestructures i serveis comuns 13
10.16 Notificació dels incompliments 14
10.17 Compliment 14
10.18 Responsabilitat del present sistema de gestió de la seguretat de la informació 14
11 Dades de caràcter personal 14
12 Prestació de serveis a TERCERES PARTS per part del Comú 15
13 Excepcions al Sistema de gestió de la seguretat de la informació 15

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

14 Desenvolupament de la política de seguretat de la informació 15
15 Aprovació, Revisió i actualitzacions 15
16 Divulgació 16

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

1 Aprovació i entrada en vigor

Aquesta "Política de Seguretat de la Informació" (d'ara endavant, Política) serà efectiva des de la data d'aprovació i fins que sigui reemplaçada per una nova Política.

2 Introducció

El Comú d'Encamp (d'ara endavant, el Comú) depèn dels sistemes TIC (Tecnologies de la Informació i Comunicació). Aquests sistemes han de ser administrats amb diligència, prenent les mesures adequades per protegir-los davant danys accidentals o deliberats que puguin afectar la disponibilitat, integritat o confidencialitat de la informació tractada o els serveis prestats.

L'objectiu de la seguretat de la informació és garantir la qualitat de la informació i la prestació continuada dels serveis, actuant preventivament, supervisant l'activitat diària i reaccionant amb prestesa als incidents.

Els processos del Comú han d'estar protegits contra amenaces de ràpida evolució amb potencial per incidir en la confidencialitat, integritat, disponibilitat, ús previst i valor de la informació i els serveis. Per defensar-se d'aquestes amenaces, es requereix una estratègia que s'adapti als canvis en les condicions de l'entorn per garantir la prestació contínua dels serveis. Això implica que el personal del Comú, la ciutadania, els proveïdors i altres parts que es relacionin amb el Comú han d'aplicar les mesures mínimes de seguretat exigides per aquesta Política, així com fer un seguiment continu dels nivells de prestació de serveis, seguir i analitzar les vulnerabilitats reportades i preparar una resposta efectiva als incidents per garantir la continuïtat dels serveis prestats.

Els diferents departaments s'han de cerciorar que la seguretat TIC és una part integral de cada etapa del cicle de vida del sistema, des de la seva concepció fins a la seva retirada de servei, passant per les decisions de desenvolupament o adquisició i les activitats d'explotació. Els requisits de seguretat i les necessitats de finançament han d'ésser identificats i inclosos en la planificació, en la sol·licitud d'ofertes i en els plecs de licitació.

Els departaments han d'estar preparats per prevenir, detectar, reaccionar i recuperar-se d'incidents.

3 Missió del Comú

El Comú, per a la gestió dels seus interessos i de les funcions i competències que té atribuïdes, promou activitats i presta serveis públics que contribueixen a satisfer les necessitats i aspiracions de la ciutadania. Per a això posa a disposició d'aquesta, la realització de tràmits online amb l'objectiu d'impulsar la tramitació electrònica dels procediments administratius, la millora en la prestació dels serveis i la participació de la ciutadania en els assumptes públics, establint, d'aquesta manera, noves vies de participació que garanteixin el desenvolupament de la democràcia participativa i la millora de l'eficàcia i eficiència de l'acció pública.

Es vol potenciar d'altra banda l'ús de les noves tecnologies al Comú i a la pròpia ciutadania. Els principals objectius que es persegueixen entre d'altres són: fomentar la relació electrònica

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

de la ciutadania amb el Comú i crear la confiança necessària entre la ciutadania i el Comú en aquesta relació.

4 Abast

Aquesta Política s'aplica a tot el personal del Comú i als contractistes i proveïdors externs que tinguin accés als actius d'informació del Comú. Cobreix tots els actius d'informació, inclosos, entre d'altres, la informació electrònica, física i verbal. La Política s'aplica a tots els dispositius, sistemes, xarxes i instal·lacions propietat o operats pel Comú, independentment de la seva ubicació.

Aquesta Política aplica especialment a aquells sistemes d'informació del Comú que estan relacionats amb l'exercici dels drets per mitjans electrònics, amb el compliment dels deures per mitjans electrònics, amb l'accés a la informació o al procediment administratiu i en general a tots aquells sistemes que donin suport a la prestació dels serveis públics del Comú.

5 Normativa de referència

La base normativa que afecta el desenvolupament de les activitats i competències del Comú i que està relacionada amb la Seguretat de la Informació, està constituïda per les següents lleis, normes i regulacions del sector vigents en el moment de redacció d'aquesta Política:

- Llei 14/2023, del 3 de juliol, de text consolidat del Codi de l'Administració.
- Llei 22/2022, del 9 de juny, de mesures per a la seguretat de les xarxes i dels sistemes d'informació (d'ara endavant, Llei NIS-AD).
- Decret 417/2022, del 12-10-2022, pel qual s'aprova el Reglament de l'Esquema nacional de seguretat del Principat d'Andorra (d'ara endavant, ENS-AD).
- Decret 418/2022, del 12-10-2022, pel qual s'aprova el Reglament d'infraestructures crítiques del Principat d'Andorra (d'ara endavant, RIC-AD).
- Resolucions, guies, recomanacions i instruccions de l'ANC-AD (Agència Nacional de Ciberseguretat d'Andorra).
- Decret 391/2022, del 28-9-2022 d'aprovació del Reglament d'aplicació de la Llei 29/2021, del 28 d'octubre, qualificada de protecció de dades personals.
- Resolucions, guies, recomanacions i instruccions de l'APDA (Agència Andorrana de Protecció de Dades).
- Decret 460/2022, 9-11-2022, d'interoperabilitat del Principat d'Andorra.
- Llei 34/2002, d'11 de juliol, de serveis de la societat de la informació i el comerç electrònic.
- Conveni sobre la cibercriminalitat i del Protocol addicional del Conveni sobre la cibercriminalitat relatiu a la incriminació d'actes de caràcter racista i xenòfob comesos per mitjà de sistemes informàtics.
- Llei 23/2011, del 29 de desembre, per la qual es constitueix la Societat de Gestió Col·lectiva de Drets d'Autor i Drets Veïns del Principat d'Andorra.
- Conveni de París per a la Protecció de la Propietat Industrial, de 20 de març de 1883.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

- Proposta d'adhesió del Principat d'Andorra a l'Organització Mundial de la Propietat Intel·lectual (OMPI), de 30-6-94 i Conveni pel qual s'institueix l'Organització Mundial de la Propietat Intel·lectual.
- Llei 35/2014, del 27 de novembre, de certificació i confiança electrònica, modificada per la Llei 9/2021, del 29 d'abril, de modificació de la Llei 35/2014, del 27 de novembre, de serveis de confiança electrònica.
- Llei 33/2021, del 2 de desembre, de transparència, accés a la informació pública i govern obert.
- Llei 29/2021, del 28 d'octubre, qualificada de protecció de dades personals del Principat d'Andorra (d'ara endavant, "l'LQPD")
- Decret 391/2022, del 28-9-2022, d'aprovació del Reglament d'aplicació de l'LQPD
- Decret 45/2023, del 25-1-2023, d'aprovació del Reglament de modificació del Reglament d'aplicació de l'LQPD
- El Reglament (UE) 2016/679 del Parlament Europeu i del Consell, del 27 d'abril del 2016, relatiu a la protecció de les persones físiques respecte al tractament de dades personals i a la lliure circulació d'aquestes dades (en endavant, "l'RGPD")

També formen part del marc normatiu les restants normes aplicables a l'Administració Electrònica del Comú.
Així mateix, el Comú serà el responsable d'identificar les guies de seguretat de l'ANC-AD, referenciades en el present article i que siguin d'aplicació per a millorar el compliment de l'establert en la Llei NIS-AD, l'ENS-AD i el RIC-AD.

6 Motivació del sistema de gestió de seguretat de la informació

Cada dia són més les amenaces i variants d'atacs que poden posar en risc la informació, així com els sistemes utilitzats per al tractament. Aquest escenari ens obliga a comptar amb un sistema que ens permeti gestionar aquests riscos de manera controlada, per garantir que s'estan protegint correctament els actius d'informació, s'estan detectant els atacs que es reben i es compta amb un pla de resposta a incidents per donar resposta ràpida i eficaç a possibles problemes de seguretat. Tots aquests aspectes, es regularan mitjançant un sistema de gestió de seguretat de la informació (SGSI).

La implantació d'un SGSI, com passa amb altres sistemes de gestió com el de qualitat, és una decisió estratègica que persegueix l'objectiu principal de garantir les tres dimensions bàsiques de la seguretat: confidencialitat, integritat i disponibilitat. Aquest sistema sempre estarà recolzat per un procés continu de Gestió de Riscos per assegurar el tractament adequat dels riscos identificats i estarà integrat amb la resta dels processos.

És un model per crear, implementar, supervisar, revisar, mantenir i millorar la protecció dels actius d'informació. La base o la referència d'aquest sistema sempre serà la Política de Seguretat de la Informació, on es plasmarà el seu context, els requisits de seguretat i l'estratègia per aconseguir els objectius. El sistema estarà basat en una avaluació continuada dels riscos que permeti una gestió eficaç i eficient dels mateixos, i inclourà lideratge, estructura organitzativa, polítiques, planificació, rols, responsabilitats, procediments, recursos i processos per a una reeixida implementació del sistema.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

Per el tractament dels riscos que tinguin relació amb les dades de caràcter personals, s'haurà de tenir em compte la Política de Protecció de Dades Personals així com altres normes de Protecció de Dades que s'estableixin dins del Comú.

L'èxit d'aquesta implementació dependrà del grau d'entesa que es té del seu context (legal, polític, geogràfic, etc.) i dels requisits de seguretat, tant per compliment normatiu, com per les necessitats pròpies de les parts interessades (personal del Comú, ciutadania, contractistes i proveïdors). Així mateix, és fonamental comptar en tot moment amb el lideratge i la supervisió per garantir el bon funcionament del sistema i detectar oportunitats de millora, amb l'aplicació del Cicle de Deming (PDCA, Plan-Do-Check-Act) .

7 Objectius de seguretat de la informació

L'objectiu d'aquesta Política és definir les línies d'actuació que conformen l'estratègia en matèria de seguretat de la informació i desenvolupar unes directrius clares i concises per a la gestió i la protecció dels actius d'informació del Comú i l'ús adequat d'aquests actius. Per assolir-ho, els axiomes a seguir són:

- Confidencialitat: Protegir la confidencialitat dels actius d'informació mitjançant la implementació de controls d'accés i mecanismes de protecció de dades adequats.
- Integritat: Garantir la integritat dels actius d'informació mitjançant la implementació de controls per evitar la modificació, supressió o destrucció no autoritzada de dades.
- Disponibilitat: Assegurar la disponibilitat dels actius d'informació mitjançant la implementació de mesures adequades de còpia de seguretat i recuperació de desastres i minimitzant l'impacte dels incidents.
- Compliment: Garantir el compliment de la normativa i les obligacions contractuals aplicables relacionades amb la seguretat de la informació.

8 Estructura del Sistema de Gestió de la Seguretat de la Informació

El conjunt de documents de la Política està estructurat en el model jeràrquic següent de quatre (4) tipologies d'estàndards normatius:

- Política: És el present document. Aquest estàndard manifesta els principis de seguretat de la informació que s'han de desenvolupar als documents dels següents nivells jeràrquics.
- Normatives: Estàndards de caràcter regulador en els quals es defineixen els objectius de control desenvolupant cadascun dels principis de seguretat de la informació detallats a en la present Política.
- Procediments: Estàndards que determinen les actuacions concretes que s'han de seguir per implantar els objectius de control definits a la normativa. Aquests estàndards emanen de les normatives o altres procediments.
- Instruccions tècniques: Estàndards que determinen com implantar els requeriments en matèria de seguretat de la informació. Aquesta categoria inclou també manuals,

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

formularis i models, entre d'altres. Aquests estàndards emanen dels procediments o altres instruccions tècniques.

Tots els estàndards normatius són de compliment obligat. No tenen validesa les disposicions que en contradiguin una altra de rang superior.

9 Organització de la seguretat

L'organització de la Seguretat de la Informació al Comú s'estableix de la manera que s'indica a continuació.

9.1 Rols o perfils de seguretat

Per garantir el compliment i l'adaptació de les mesures exigides reglamentàriament, s'han creat rols o perfils de seguretat i s'han designat els càrrecs o òrgans que els ocuparan, de la manera següent:

- Responsable de Tecnologies de la Informació i la Comunicació (RTIC).
- Delegat de la Seguretat de la Informació (DSI).
- Delegat de Protecció de Dades (DPD).

9.2 Comitè de Seguretat de la Informació

El Comú ha constituït un Comitè de Seguretat de la Informació, com a òrgan col·legiat, i està format per com a mínim els membres següents:

- President: Responsable de Tecnologies de la Informació i la Comunicació (RTIC).
- Vicepresident: Delegat de la Seguretat de la Informació (DSI).
- Vocal: Delegat de Protecció de Dades (DPD).
- Vocal: Membre del Gabinet Jurídic

Amb caràcter opcional, altres membres del Comú podran incorporar-se a les tasques del Comitè, inclosos grups de treball especialitzats, ja siguin de caràcter intern, extern o mixt.

El Comitè de Seguretat de la Informació celebrarà les seves sessions amb periodicitat trimestral, prèvia convocatòria a aquest efecte realitzada pel president del Comitè de Seguretat de la Informació.

9.3 Dades de contacte del DSI

Les dades de contacte del DSI son les que estan informades al registre de l'Agencia Nacional de Ciberseguretat.

10 Requisits de seguretat bàsics

El Comú, per assolir els principis bàsics i dels requisits mínims de seguretat, ha d'implementar diverses mesures de seguretat proporcionals a la naturalesa de la informació i els serveis a protegir i tenint en compte la categoria dels sistemes afectats.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

10.1 Seguretat com un procés integral

La seguretat s'entén com un procés integral constituït per tots els elements tècnics, humans, materials i organitzatius relacionats amb el sistema. L'aplicació d'aquesta Política estarà presidida per aquest principi, que exclou qualsevol actuació puntual o tractament conjuntural.

Es prestarà la màxima atenció a la conscienciació de les persones que intervenen en el procés i als seus responsables jeràrquics, per evitar que la ignorància o la manca d'organització i coordinació, o d'instruccions inadequades, siguin font de risc per a la seguretat.

10.2 Principi de mínim privilegi

Els sistemes d'informació es dissenyaran de manera que garanteixin la seguretat per defecte, de la manera següent:

- El sistema proporcionarà la mínima funcionalitat requerida per la prestació dels serveis comunals.
- Les funcions d'operació, administració i registre d'activitat seran les mínimes necessàries, i s'assegurarà que només són accessibles per les persones autoritzades i o des d'emplaçaments o equips autoritzats, podent exigir-se, en el seu cas, restriccions d'horari i punts d'accés autoritzats.
- En un sistema d'explotació s'eliminaran o desactivaran, mitjançant el control de la configuració, les funcions que siguin innecessàries o inadequades al fi que es persegueix. L'ús ordinari del sistema ha de ser senzill i segur, de manera que una utilització insegura requereixi d'un acte conscient per part de l'usuari.
- S'aplicaran guies de configuració de seguretat per a les diferents tecnologies, adaptades a la categorització del sistema, a l'efecte d'eliminar o desactivar las funcions que siguin innecessàries o inadequades.

10.3 Vigilància contínua, reavaluació periòdica i Integritat, actualització del sistema i millora contínua del procés de seguretat

La vigilància contínua per part del Comú permetrà la detecció d'activitats o comportaments anòmals i la seva oportuna resposta.

L'avaluació permanent de l'estat de la seguretat dels actius permetrà mesurar la seva evolució, detectant vulnerabilitats i identificant deficiències de configuració.

Les mesures de seguretat es reavaluaran i actualitzaran periòdicament, adequant la seva eficàcia a l'evolució dels riscos i els sistemes de protecció, podent arribar a un replantejament de la seguretat, si fos necessari.

La inclusió de qualsevol element físic o lògic en el catàleg actualitzat d'actius del sistema, o la seva modificació, requerirà autorització formal prèvia.

L'avaluació i monitoratge permanents permetran adequar l'estat de seguretat dels sistemes atenent les deficiències de configuració, les vulnerabilitats identificades i les actualitzacions que els afectin, així com la detecció primerenca de qualsevol incident que tingui lloc sobre els mateixos.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

El procés integral de seguretat implantat haurà de ser actualitzat i millorat de forma contínua. Per a això, s'aplicaran els criteris i mètodes reconeguts en la pràctica nacional i internacional relatius a la gestió de la seguretat de les tecnologies de la informació.

Així mateix, es demanarà la revisió periòdica per part de tercers per tal d'obtenir una avaluació independent.

10.4 Gestió de personal i professionalitat

Tot el personal relacionat amb els sistemes d'informació del Comú assistirà a una sessió de conscienciació en matèria de seguretat com a mínim una vegada a l'any. S'establirà un programa de conscienciació contínua per atendre tot el personal, en particular el de nova incorporació.

Les persones amb responsabilitat en l'ús, operació i/o administració de sistemes TIC rebran formació per al maneig segur dels sistemes en la mesura que la necessitin per realitzar el seu treball. La formació serà obligatòria abans d'assumir una responsabilitat, tant si és la seva primera assignació o si es tracta d'un canvi de lloc de treball o de responsabilitats en el mateix.

Tot el personal, propi o aliè relacionat amb els sistemes d'informació del Comú serà supervisat per verificar que es segueixen els procediments establerts.

El significat i abast de l'ús segur dels sistemes i/o dispositius es concretarà i plasmarà en unes normes de seguretat que seran aprovades per l'òrgan corresponent.

Es determinaran els requisits de formació i experiència necessària del personal per al desenvolupament del seu lloc de treball.

La seguretat dels sistemes d'informació estarà atesa i serà revisada i auditada per personal qualificat, dedicat i instruït en totes les fases del seu cicle de vida: planificació, disseny, adquisició, construcció, desplegament, explotació, manteniment, gestió d'incidències i desmantellament.

De manera objectiva i no discriminatòria el Comú exigirà que els empresaris que presten serveis al Comú comptin amb professionals qualificats i amb uns nivells idonis de gestió i maduresa dels serveis prestats.

10.5 Gestió de la seguretat basada en els riscos i anàlisi i gestió de riscos

L'anàlisi i la gestió dels riscos serà part essencial del procés de seguretat i serà una activitat contínua i permanentment actualitzada.

La gestió dels riscos permetrà el manteniment d'un entorn controlat, minimitzant els riscos a nivells acceptables. La reducció a aquests nivells es realitzarà mitjançant una apropiada aplicació de mesures de seguretat, de manera equilibrada i proporcionada a la naturalesa de la informació tractada, dels serveis a prestar i dels riscos als quals estiguin exposats.

Tots els sistemes afectats per aquesta Política, així com tots els tractaments de dades personals, hauran de ser objecte d'una anàlisi de riscos, avaluant les amenaces i els riscos als quals estan exposats. Aquesta anàlisi es repetirà:

- Regularment, almenys una vegada a l'any.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

- Quan canviïn els serveis prestats i/o la informació tractada de manera significativa.
- Quan s'esdevingui un incident greu de seguretat o es detectin vulnerabilitats greus.

El DSI (Delegat de Seguretat de la Informació) serà l'encarregat que es realitzi l'anàlisi de riscos, així com d'identificar mancances i debilitats i posar-les en coneixement del Comitè de Seguretat de la Informació.

Aquesta gestió es realitzarà per mitjà de l'anàlisi i tractament dels riscos als quals està exposat el sistema. S'emprarà alguna metodologia reconeguda internacionalment. Les mesures adoptades per mitigar o suprimir els riscos hauran d'estar justificades i, en tot cas, existirà una proporcionalitat entre elles i els riscos.

10.6 Incidents de seguretat, prevenció, reacció i recuperació

El Comú implementa un procés integral de detecció, reacció i recuperació davant de codi danyós mitjançant el desenvolupament de procediments que cobreixen els mecanismes de detecció, els criteris de classificació, els procediments d'anàlisi i resolució, així com les vies de comunicació a les parts interessades i el registre de les actuacions. Aquest registre s'emprarà per a la millora contínua de la seguretat del sistema.

- Les mesures de prevenció podran incorporar components orientats a la dissuasió o a la reducció de la superfície d'exposició i han d'eliminar o reduir la possibilitat que les amenaces arribin a materialitzar-se.
- Les mesures de detecció aniran dirigides a descobrir la presència d'un ciberincident.
- Les mesures de resposta es gestionaran en temps oportú, estaran orientades a la restauració de la informació i els serveis que poguessin haver-se vist afectats per un incident de seguretat.
- El sistema d'informació garantirà la conservació de les dades i informació en suport electrònic.

Perquè la informació i/o els serveis no es vegin perjudicats per incidents de seguretat, el Comú implementa les mesures de seguretat establertes per la Llei NIS-AD, l'ENS-AD i el RIC-AD, així com qualsevol altre control addicional, que hagi identificat com a necessari, a través d'una avaluació d'amenaces i riscs. Aquests controls, així com els rols i les responsabilitats de seguretat de tot el personal, estan clarament definits i documentats.

Quan es produeix una desviació significativa dels paràmetres que s'hagin preestablert com a normals, s'establiran els mecanismes de detecció, anàlisi i informe necessaris perquè arribin als responsables regularment.

El Comú establirà les següents mesures de reacció davant d'incidents de seguretat:

- Mecanismes per respondre eficaçment als incidents de seguretat.
- Designar un punt de contacte per a les comunicacions respecte a incidents detectats en altres departaments del Comú o en altres organismes.
- Establir protocols per a l'intercanvi d'informació relacionada amb l'incident. Això inclou comunicacions, en ambdós sentits, amb els Equips de Resposta a Emergències (CERT).
- Per garantir la disponibilitat dels serveis, el Comú disposa dels mitjans i les tècniques necessàries que permeten garantir la recuperació dels serveis més crítics.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

10.7 Línies de defensa i prevenció davant d'altres sistemes interconnectats

El Comú implementarà una estratègia de protecció del sistema d'informació constituïda per múltiples capes de seguretat, constituïdes per mesures organitzatives, físiques i lògiques, de manera que quan una capa sigui compromesa, permeti desenvolupar una reacció adequada davant dels incidents que no s'han pogut evitar, reduint la probabilitat de que el sistema sigui compromès en el seu conjunt i minimitzar-ne l'impacte final.

Es protegirà el perímetre del sistema d'informació, especialment quan el sistema del Comú es connecta a xarxes públiques, reforçant-se les tasques de prevenció, detecció i resposta a incidents de seguretat.

En tot cas, s'analitzaran els riscos derivats de la interconnexió del sistema amb altres sistemes i es controlarà el seu punt d'unió. Per a l'adequada interconnexió entre sistemes cal atenir-se al que disposa la Instrucció Tècnica de Seguretat corresponent.

10.8 Funció diferenciada i organització i implantació del procés de seguretat

El Comú organitzarà la seva seguretat mitjançant la designació de diferents rols de seguretat amb responsabilitats clarament diferenciades, tal com es recull a l'apartat "ORGANITZACIÓ DE LA SEGURETAT" del present document.

10.9 Autorització i control dels accessos

El Comú implementarà mecanismes de control d'accés als sistemes d'informació, als usuaris, als processos, als dispositius i altres sistemes d'informació, perquè quedin degudament autoritzats, i puguin fer us de les funcions exclusivament permeses.

10.10 Protecció de les instal·lacions

El Comú implementarà mecanismes de control d'accés físic, prevenint els accessos físics no autoritzats, així com els danys a la informació i als recursos, mitjançant perímetres de seguretat, controls físics i proteccions generals en àrees.

10.11 Adquisició de productes de seguretat i contractació de serveis de seguretat

Per a l'adquisició de productes de seguretat, el Comú tindrà en compte que aquests tinguin certificada la funcionalitat de seguretat relacionada amb l'objecte de la seva adquisició, excepte en aquells casos en què les exigències de proporcionalitat pel que fa als riscos assumits no ho justifiquin.

Per a la contractació de serveis de seguretat s'atendrà a l'assenyalat en l'article 10.4 quant a la professionalitat.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

10.12 Protecció de la informació emmagatzemada i en trànsit

El Comú prestarà especial atenció a la informació emmagatzemada o en trànsit a través dels equips o dispositius portàtils o mòbils, els dispositius perifèrics, els suports d'informació i les comunicacions sobre xarxes obertes, que s'han d'analitzar especialment per aconseguir una protecció adequada.

10.13 Continuïtat de l'activitat

S'aplicaran procediments que garanteixin la recuperació i conservació a llarg termini dels documents electrònics produïts pels sistemes d'informació compresos en l'àmbit d'aplicació d'aquesta Política, quan això sigui exigible.

Tota informació en suport no electrònic que hagi estat causa o conseqüència directa de la informació electrònica a què es refereix aquesta Política, haurà d'estar protegida amb el mateix grau de seguretat que aquesta. Per a això, s'aplicaran les mesures que corresponguin a la naturalesa del suport, de conformitat amb les normes que resultin d'aplicació.

Els sistemes disposaran de còpies de seguretat i s'establiran els mecanismes necessaris per garantir la continuïtat de les operacions en cas de pèrdua dels mitjans habituals.

10.14 Registres d'activitat

El Comú, amb garanties plenes del dret a la intimitat, a l'honor i a la pròpia imatge dels afectats, i d'acord amb la normativa sobre protecció de dades personals, de funció pública i altres disposicions que siguin aplicables, registrarà les activitats dels usuaris, retenint la informació estrictament necessària per monitoritzar, analitzar, investigar i documentar activitats indegudes o no autoritzades, permetent identificar en cada moment la persona que actua.

Per tal de preservar la seguretat dels sistemes d'informació, garantint la rigorosa observança dels principis d'actuació de les administracions públiques, i de conformitat amb el que disposa l'LQPD i el respecte als principis de limitació de la finalitat, minimització de les dades i limitació del termini de conservació que s'hi estableixen, es podrà, en la mesura estrictament necessària i proporcionada, analitzar les comunicacions entrants o sortints, i únicament per a les finalitats de seguretat de la informació, de forma que sigui possible impedir l'accés no autoritzat a les xarxes i sistemes d'informació, aturar els atacs de denegació de servei, evitar la distribució malintencionada de codi danyós així com altres danys a les esmentades xarxes i sistemes d'informació.

Cada usuari que accedeixi al sistema d'informació haurà d'estar identificat de forma única, de manera que se sàpiga, en tot moment, qui rep drets d'accés, de quin tipus són aquests, i qui ha realitzat una determinada activitat.

10.15 Infraestructures i serveis comuns

El Comú tindrà en compte la seguretat en la utilització d'infraestructures i serveis comuns de les administracions públiques, inclosos els compartits o transversals.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

10.16 Notificació dels incompliments

Tal i com s'estableix a la Llei NIS-AD, el Comú notificarà els incidents de seguretat en el termini màxim establert.

Tot el personal i tots els contractistes i proveïdors externs del Comú estan obligats a informar al DSI de qualsevol sospita d'infracció d'aquesta Política o infracció de seguretat que pugui afectar o afecti al Comú sense demora i en cap cas en un termini màxim de 48 hores des de la detecció.

10.17 Compliment

Aquesta Política proporciona cobertura a aspectes recollits en els següents estàndards de seguretat de la informació reconeguts internacionalment:

- Tecnologia de la informació. Tècniques de seguretat. Sistemes de gestió de la seguretat de la informació. Requisits (ISO/IEC 27001)
- Tecnologia de la informació. Tècniques de seguretat. Codi de pràctiques per als controls de seguretat de la informació (ISO/IEC 27002)

Per al desenvolupament de la present Política s'han pres com a referència els requeriments previstos en normatives, com el Reglament General de Protecció de Dades europeu (RGPD), l'LQPD, la Llei NIS-AD, l'ENS-AD, i el RIC-AD. Les normatives i estàndards de seguretat de la informació contemplats a l'abast de la política estaran detallades al Marc Normatiu de Seguretat de la Informació.

10.18 Responsabilitat del present sistema de gestió de la seguretat de la informació

Tot el personal i tots els col·laboradors interns i externs del Comú són responsables d'assegurar el compliment dels principis de la present Política i del que s'ha desenvolupat en els documents normatius interns del Comú que emanen d'aquesta, així com de la normativa vigent en matèria de seguretat de la informació.

El Comú es reserva el dret d'emprendre accions legals o disciplinàries en situacions d'incompliment de la present Política.

11 Dades de caràcter personal

El Comú només tractarà dades de caràcter personal adequades, pertinents i limitades al que és necessari en relació amb les finalitats per a les quals es tracten.

De la mateixa manera, el Comú aplicarà les mesures tècniques i organitzatives adequades, de manera que el tractament sigui conforme als requisits de la normativa de protecció de dades.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

12 Prestació de serveis a TERCERES PARTS per part del Comú

Quan el Comú presti serveis a altres entitats, o gestioni informació d'altres entitats, se les farà partícips d'aquest Sistema de Gestió de Seguretat de la Informació. El Comú definirà i aprovarà els canals per a la coordinació de la informació i els procediments d'actuació per a la reacció davant d'incidents de seguretat, així com la resta d'actuacions que el Comú dugui a terme en matèria de seguretat en relació amb altres entitats.

Quan el Comú utilitzi serveis de tercers o cedeixi informació a tercers, se'ls farà partícips d'aquest Sistema de Gestió de Seguretat de la Informació existent que afecta a aquests serveis o informació.

13 Excepcions al Sistema de gestió de la seguretat de la informació

Les excepcions al sistema de gestió de la seguretat de la informació seran estudiades cas per cas i mitjançant un informe justificatiu de la excepció que contindrà com a mínim els següents elements: justificació de la excepció, responsable de la excepció, valoració dels riscos associats, mesures mitigadores dels riscos associats i aprovació per part del DSI o responsable de l'aprovació.

14 Desenvolupament de la política de seguretat de la informació

El Comitè de Seguretat de la Informació ha aprovat el desenvolupament d'un sistema de gestió, que serà establert, implementat, mantingut i millorat conforme als estàndards de seguretat. El sistema serà documentat i permetrà generar evidències dels controls i del compliment dels objectius marcats pel Comitè. Existirà un procediment de gestió documental que establirà les directrius per a l'estructuració de la documentació de seguretat del sistema, la seva gestió i accés.

15 Aprovació, Revisió i actualitzacions

L'aprovació del present document correspon a la Junta de Govern.

Correspon al Comitè de Seguretat de la Informació la revisió anual o quan sigui necessari per assegurar la idoneïtat, adequació i eficàcia continuades de la present Política, proposant en cas que sigui necessari, millores de la mateixa, per a la seva aprovació per part de la Junta de Govern.

Qualsevol canvi en la Política s'ha de comunicar a tot el personal del Comú i altres parts interessades.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.

16Divulgació

Aquesta Política es dona a conèixer a tots els usuaris dels sistemes d'informació i de comunicacions del Comú.

A les entitats que en l'àmbit d'una relació administrativa o comercial tractin informació titularitat del Comú o sota la responsabilitat del Comú se'ls exigirà l'adhesió al Sistema de Gestió de la Seguretat de la Informació i reconèixer-ne la responsabilitat de complir i vetllar el compliment dels requisits aplicables en matèria de seguretat de la informació.

Document confidencial. Tots els drets reservats. Queda prohibida la reproducció, la comunicació o l'accés a tercers no autoritzats.